

Reporte Ejecutivo de Auditoría de Seguridad

1. Resumen Ejecutivo

Score de Seguridad General: 30 / 100

Justificación del Score: La puntuación de 30/100 refleja una postura de seguridad deficiente, principalmente debido a la exposición de servicios de alto riesgo como Samba (SMB/CIFS) y una gran cantidad de puertos asociados a Docker, lo que amplía significativamente la superficie de ataque. Se identificaron configuraciones de usuario inseguras, como una cuenta de sistema con un shell interactivo inapropiado y el acceso directo de 'root'. Además, la presencia de un servicio 'systemd' escuchando en un puerto no estándar y la exposición de herramientas de monitoreo contribuyen a la baja calificación.

Evaluación Gerencial

El servidor auditado presenta una postura de seguridad débil que requiere atención inmediata. Se han detectado múltiples vulnerabilidades críticas y de alto impacto, incluyendo la exposición de servicios de compartición de archivos (SMB/CIFS) que son blancos frecuentes de ataques, y una extensa superficie de ataque generada por numerosos puertos abiertos de Docker. La gestión de usuarios muestra deficiencias, con una cuenta de sistema configurada de forma insegura y la posibilidad de acceso directo como 'root'. Estas debilidades representan un riesgo significativo para la integridad y confidencialidad de los datos, así como para la disponibilidad del servicio. Se recomienda priorizar las mitigaciones propuestas para fortalecer la seguridad del sistema.

2. Hallazgos Prioritarios

- Exposición de servicios SMB/CIFS (puertos 139, 445 TCP y 137, 138 UDP) a la red.
- Gran superficie de ataque debido a la exposición de múltiples puertos de docker-proxy.
- Cuenta de sistema User_1 (UID 4) con shell interactiva /bin/sync.
- Servicio systemd escuchando en el puerto 9090/tcp.
- Acceso directo de root con shell /bin/bash.

3. Matriz de Riesgos Detectados

ID	Riesgo Detectado	Nivel de Impacto	Descripción
R-01	Exposición de Servicios SMB/CIFS	Crítico	Los servicios SMB/CIFS (Samba) están expuestos en los puertos TCP 139, 445 y UDP 137, 138. Estos servicios son conocidos por ser vectores de ataque comunes para ransomware, gusanos y exfiltración de datos, especialmente si están accesibles desde redes no confiables.
R-02	Amplia Superficie de Ataque por Puertos Docker	Alto	Se han detectado numerosos puertos (ej. 80, 81, 90, 443, 543, 2283, 3100, 6543, 6881, 8080, 8096, 8181, 8920, 9000, 9443 TCP y 1900, 6881, 7359 UDP) asociados a docker-proxy. Esta gran cantidad de puertos abiertos aumenta significativamente la superficie de ataque del servidor, exponiendo potencialmente servicios internos de contenedores que podrían no estar endurecidos o ser vulnerables.
R-03	Cuenta de Sistema con Shell Insegura	Alto	La cuenta User_1 (UID 4), que es una cuenta de sistema, tiene asignado el shell /bin/sync y tiene_login: true. Esto es una configuración inusual e insegura, ya que /bin/sync no está diseñado para ser un shell interactivo y podría ser explotado para obtener acceso no autorizado o escalar privilegios.

R-04	Servicio 'systemd' Expuesto en Puerto No Estándar	Alto	El proceso systemd está escuchando en el puerto TCP 9090. systemd no es un servicio que deba estar expuesto en la red de esta manera. Esto podría indicar una configuración errónea, un servicio malicioso o un componente inesperado que utiliza este nombre de proceso, creando una vulnerabilidad significativa.
R-05	Acceso Directo de Usuario 'root'	Medio	La cuenta root tiene un shell interactivo (/bin/bash) y tiene_login: true, lo que sugiere que el acceso directo como root está permitido. Esta práctica es desaconsejada ya que un ataque de fuerza bruta o credenciales comprometidas podrían otorgar control total del sistema sin un paso intermedio.
R-06	Versión de Kernel con Posibles CVEs	Medio	El servidor utiliza el kernel 6.8.0-124-generic en Ubuntu 24.04.4 LTS. Aunque es una versión reciente y soportada, no es la última revisión de seguridad disponible. Podría haber vulnerabilidades (CVEs) conocidas para esta versión específica que aún no han sido parcheadas.
R-07	Exposición de Servicios de Monitoreo (PCP)	Bajo	Los servicios de Performance Co-Pilot (PCP) como pmlogger (4330/tcp), pmcd (44321/tcp) y pmproxy (44322/tcp, 44323/tcp) están expuestos. Si bien son herramientas legítimas de monitoreo, su exposición puede permitir la recolección de información sensible sobre el rendimiento y la configuración del sistema por parte de un atacante.

R-08	Servidor de Correo (Postfix) Expuesto	Bajo	El servicio master (Postfix) está escuchando en el puerto TCP 25. Si el servidor no está destinado a funcionar como un servidor de correo, este servicio es innecesario y representa una superficie de ataque adicional. Si es un servidor de correo, requiere una configuración robusta para prevenir el abuso (ej. spam relay).
------	--	------	---

4. Recomendaciones Técnicas de Mitigación

■ ■ Restringir o deshabilitar Samba

Deshabilitar los servicios Samba si no son estrictamente necesarios. Si son necesarios, restringir el acceso únicamente a IPs de confianza mediante un firewall.

```
sudo systemctl stop smbd nmbd
sudo systemctl disable smbd nmbd
sudo ufw deny from any to any port 137,138,139,445 proto tcp
sudo ufw deny from any to any port 137,138 proto udp
sudo ufw reload
```

■ ■ Revisar y minimizar puertos expuestos por Docker

Auditar todos los contenedores Docker para identificar qué servicios están exponiendo puertos. Minimizar la exposición de puertos a solo aquellos estrictamente necesarios y restringir el acceso mediante un firewall o configuraciones de red de Docker.

```
sudo docker ps -a
sudo docker inspect <container_id>
sudo nano /etc/docker/daemon.json
sudo systemctl restart docker
```

■ ■ Cambiar shell de User_1 a nologin

Modificar el shell de la cuenta User_1 a /usr/sbin/nologin para prevenir cualquier intento de login interactivo, ya que es una cuenta de sistema y no debería tener acceso de shell.

```
sudo usermod -s /usr/sbin/nologin User_1
```

■ ■ Identificar y asegurar el servicio en 9090/tcp

Investigar qué proceso real está escuchando en el puerto 9090/tcp y por qué se reporta como systemd. Si es un servicio legítimo, asegurar su configuración y restringir el acceso. Si es innecesario o malicioso, deshabilitarlo o eliminarlo.

```
sudo lsof -i :9090
sudo netstat -tulnp | grep 9090
sudo systemctl status <servicio_identificado>
sudo ufw deny 9090/tcp
```

■ ■ Deshabilitar login directo de 'root' vía SSH

Configurar el servidor SSH para deshabilitar el login directo de root. En su lugar, los administradores deben iniciar sesión con una cuenta de usuario regular y luego usar sudo para tareas administrativas. Asegúrese de tener un usuario con permisos sudo configurado antes de aplicar este cambio.

```
sudo nano /etc/ssh/sshd_config
sudo systemctl restart sshd
```

■ ■ Actualizar el kernel a la última versión estable

Mantener el kernel del sistema operativo actualizado es crucial para aplicar parches de seguridad que corrigen vulnerabilidades conocidas (CVEs) y mejorar la estabilidad general del sistema.

```
sudo apt update
sudo apt upgrade
sudo apt dist-upgrade
sudo reboot
```

■ ■ Restringir acceso a puertos de PCP

Limitar el acceso a los puertos utilizados por Performance Co-Pilot (PCP) a solo las direcciones IP de los sistemas de monitoreo autorizados para evitar la exposición de información del sistema.

```
sudo ufw deny from any to any port 4330,44321,44322,44323 proto tcp
sudo ufw reload
```

■ ■ Asegurar o deshabilitar el servicio Postfix

Si el servidor no está destinado a ser un servidor de correo, deshabilitar Postfix y bloquear el puerto 25. Si es un servidor de correo, asegurar su configuración para prevenir el uso como relay abierto y aplicar las mejores prácticas de seguridad para SMTP.

```
sudo systemctl stop postfix
sudo systemctl disable postfix
sudo ufw deny 25/tcp
sudo ufw reload
```